

What is HTTP & HTTPS?

HTTP (HyperText Transfer Protocol)

- Works on **Port 80**.
- Data is sent in **plain text**.
- **Not secure** → attackers can sniff or tamper data.

HTTPS (HTTP Secure)

- Works on **Port 443**.
- Uses **SSL/TLS encryption**.
- **Secure communication** → protects against sniffing & man-in-the-middle attacks.

👉 Always use **HTTPS** for logins, payments, sensitive data.

◆ 3. HTTP Methods

Methods = actions that can be performed on a resource (website/page).

- **GET** → Request data (e.g., open webpage).
- **POST** → Send data (e.g., login form, file upload).
- **PUT** → Update existing resource.
- **DELETE** → Delete a resource.

👉 **Security Note:** Attackers often test these methods to exploit insecure functions.

◆ 4. HTTP Response Codes

When a client (browser) sends a request, the server replies with a **status code**.

✅ 1xx → Informational

- 100 Continue – Request received, continue process.

✅ 2xx → Success

- 200 OK – Request successful.
- 201 Created – New resource created.

✅ 3xx → Redirection

- 301 Moved Permanently – New URL.
- 302 Found – Temporary redirect.
- 304 Not Modified – Use cached version.

✅ 4xx → Client Errors

- 400 Bad Request – Invalid syntax.
- 401 Unauthorized – Need login.
- 403 Forbidden – Access denied.
- 404 Not Found – Page not found.
- 405 Method Not Allowed – Method not supported.

✓ 5xx → Server Errors

- 500 Internal Server Error – Generic server issue.
- 502 Bad Gateway – Invalid response from another server.
- 503 Service Unavailable – Server overloaded/down.
- 504 Gateway Timeout – Server didn't respond in time.

◆ 5. How Burp Suite + HTTP/HTTPS Helps in SOC / Pentest

- **Intercept GET/POST requests** to see what data is sent.
- Modify parameters → check for **SQL injection, XSS, IDOR**.
- Observe **status codes** (e.g., 401/403/500) to understand misconfigurations.
- Use **HTTPS interception** to analyze encrypted traffic (Burp installs its own SSL certificate).

Common Referrer Policies

Policy	What it Does
no-referrer	Sends no referrer at all. Full privacy.
no-referrer-when-downgrade (default)	Sends referrer only from HTTPS → HTTPS , NOT to HTTP.
origin	Sends only the domain (no path). Example: https://example.com
origin-when-cross-origin	Same-site → full referrer, Cross-site → only domain.
same-origin	Sends referrer only if the link is within the same website .
strict-origin-when-cross-origin	Most common for security. Full referrer on HTTPS → HTTPS, only domain for cross-site.
unsafe-url	Sends full URL always. Not recommended .